Fundamentals of Information Security

Final Project

Francisco Acosta | SEC285 | April 2024

Introduction

The motivation for this endeavor was to demonstrate knowledge and practical application of information security fundamentals with the intent of preparing for the CompTIA Security+ certification examination.

This module exemplifies my ability to analyze security threats with the intent of implementing solutions to prevent, isolate, and mitigate risks.

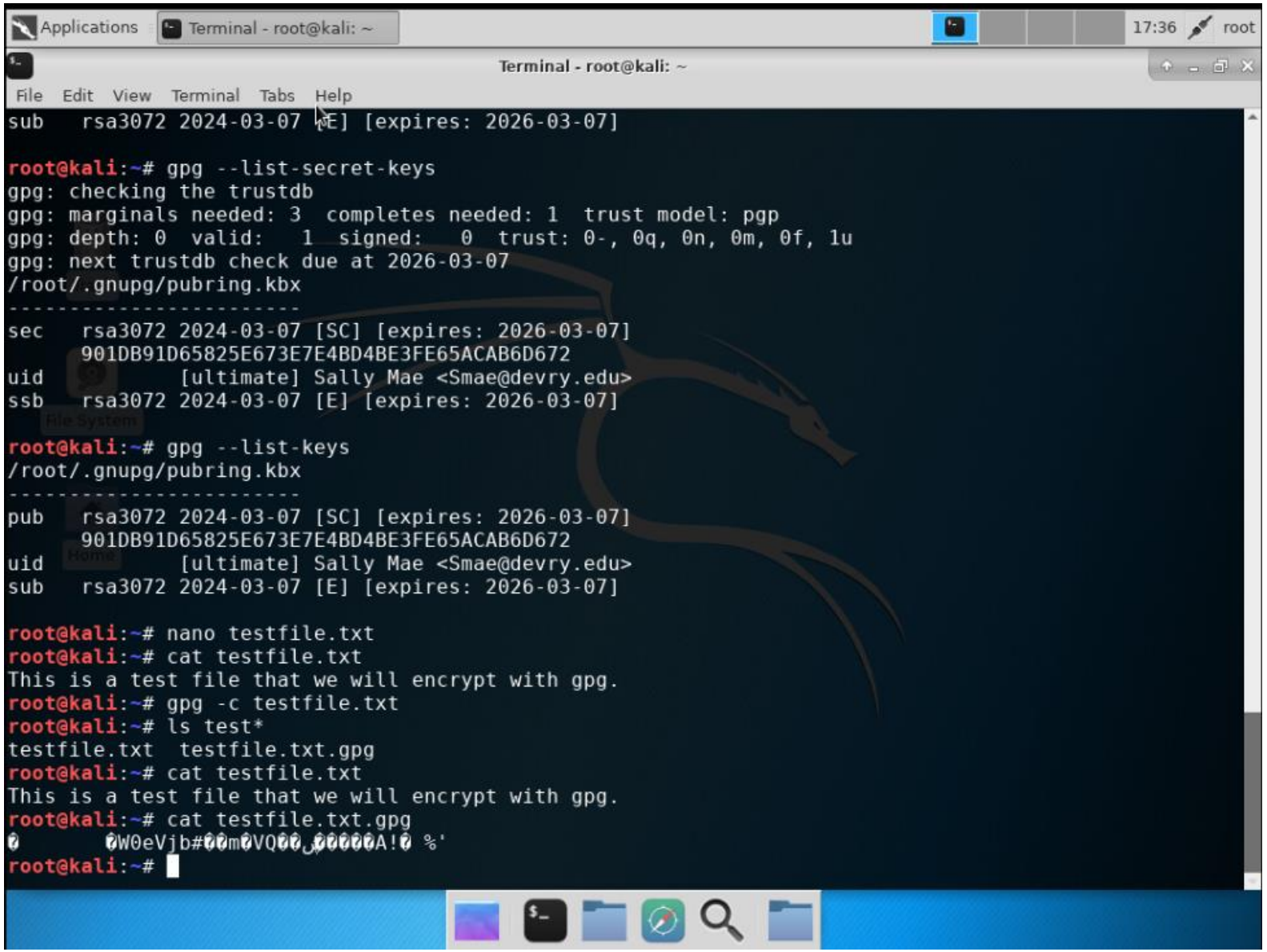
The Microsoft Hyper-V environment was utilized to demonstrate competencies of information security by means of configuration and testing.

Topics include Asymmetric Key Encryption, Stateful Firewalls, Bring Your Own Device (BYOD) Security Policies, Multifactor Authentication (MFA), Vulnerability Assessments, troubleshooting, establishing network configurations, creation of internet security solutions, and implementing digital signatures.

Asymmetric Key Encryption

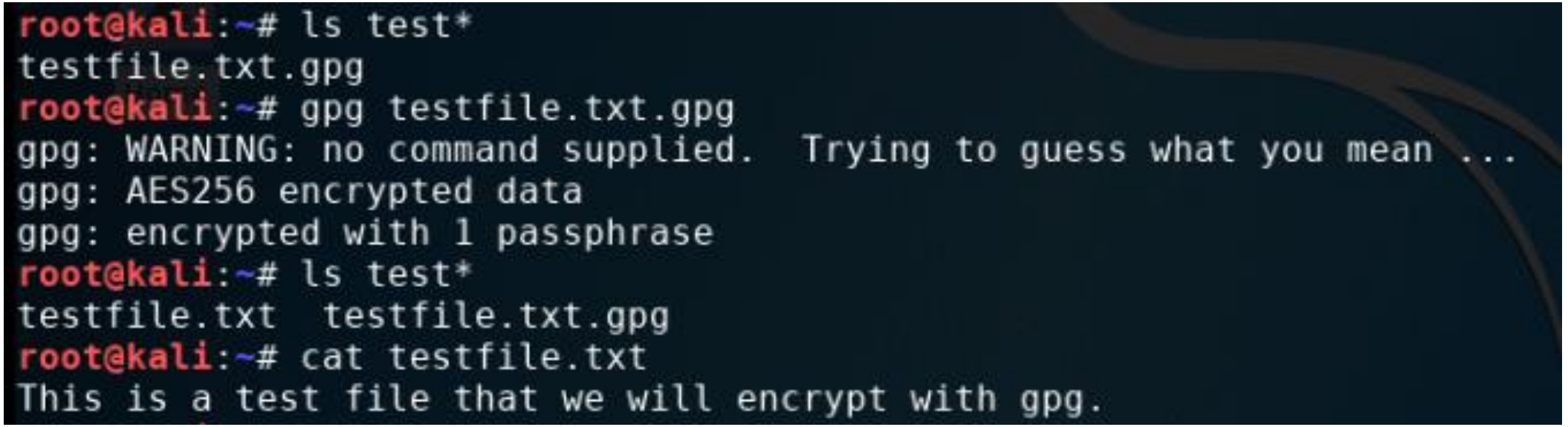
File Encryption

Plaintext file and encrypted file



File Decryption

The decryption process



Stateful Firewall

Command Line Interface (CLI) Question

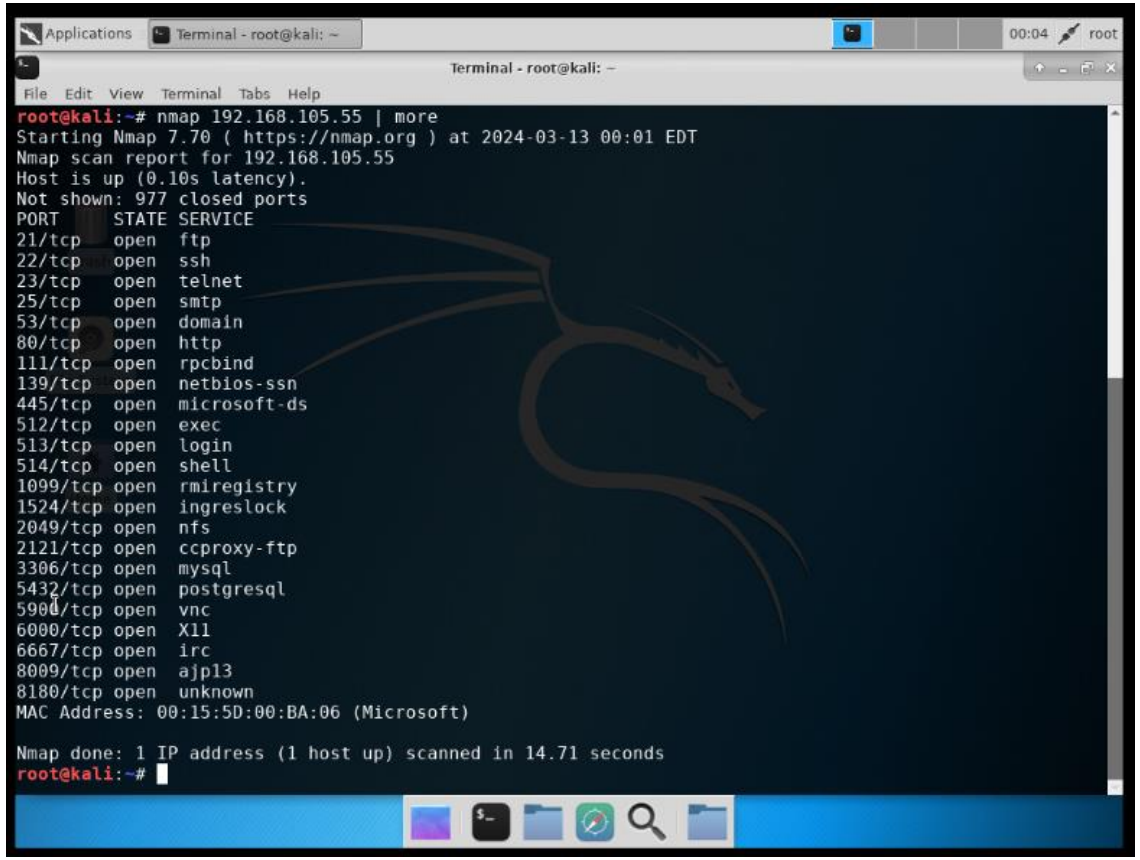
What effect does the sudo iptables --policy INPUT DROP command have on the access to computing resources?

This command drops all incoming connections and denies access to computing resources without sending a response back to incoming traffic. This enhances security by limiting traffic but may be problematic if vital ports such as port 22 (SSH) are not allowed access to computing resources.

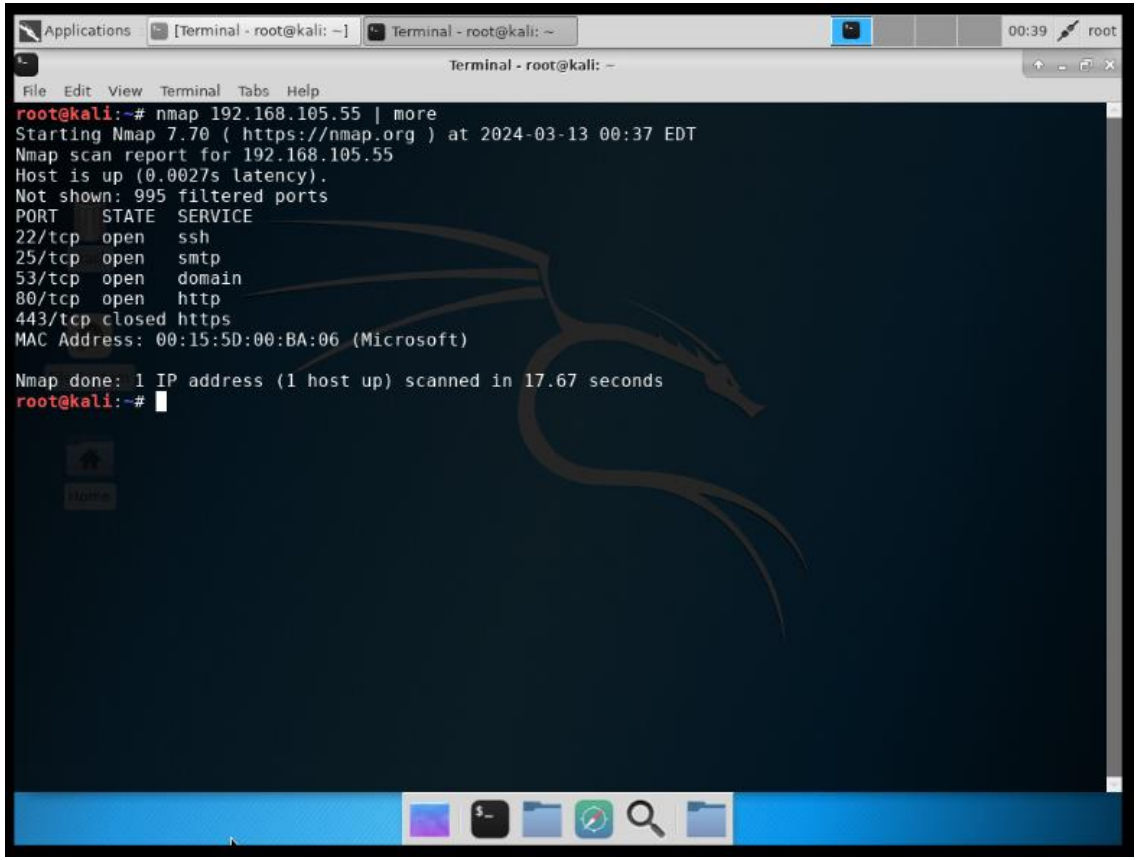
Nmap Scan

Result of the Linux Server VM

Initial Scan



Scan after iptables policy update



Bring Your Own Device (BYOD) Security Policy

BYOD Overview

Tablets, smartphones and laptops are widely used in modern enterprises across the globe.
According to Statista, 64% of United States professionals utilize smartphones and the rest of the world ranges from 59% to 43%.

Forbes states 87% of business professionals utilize a laptop as their primary device of choice.
A smartphone and a tablet came in as the second and third most used devices for business professionals.

Over half of the population utilize portable devices for business purposes and organizations saw a need to create policies to limit emerging threats. These threats consist of Madware, Spyware, Viruses, Trojans, Drive-by downloads, browser exploits, phishing, ransomware, and grayware apps to name a few.
A whole network may become compromised from a single infected device by taking advantage of the established network connection.

The creation of a “Bring Your Own Device” (BYOD) policy is the solution organizations have chosen and it has quickly become a standard for most of the professional world.
These policies ensure threats are managed to the best of the company's abilities, while keeping employees accountable for their devices and ensuring they are educated on proper safety protocols.

BYOD Purpose

The BYOD policy strives to protect confidentiality, integrity, and availability (CIA) of the organization’s assets. The introduction of personal devices in the workplace adds flexibility for all involved, however security concerns must be taken into consideration.

Vulnerabilities to the organization must be addressed in a timely manner to address gaps in security. Preparation is key to reducing damage to the organization's resources.
Alerting the InfoSec team of vulnerabilities aid in the prevention of future attacks.

Addressing vulnerabilities rapidly allows for the organization’s InfoSec team to swiftly remediate threats and create defenses to combat these vulnerabilities.

This policy secures the organization’s assets by creating standards that are applicable to all employees, contractors, and vendors. Modification to policy enables the organization to establish standardized defenses for the InfoSec to follow and allows the organization to keep rules and regulations relevant to emerging threats.

BYOD Scope

Devices must be approved by the InfoSec team to gain access the corporate network.
Smartphones, tablets, laptops and smartwatches are permissible devices, but must be kept up to date with the approved versioning of each device.

Devices connected to the organization's network must utilize InfoSec approved applications.
Any application posing a security risk or deemed unaccepted by the InfoSec team may not be utilized.
Any violation of BYOD policy is subject to disciplinary action.

Employees must adhere to BYOD policy and are responsible for reporting security breaches, as well as lost or stolen devices.

Department leadership is responsible for ensuring employees in their department adhere to policy and may be subject to internal or externals audits.

Technical support is readily available through the InfoSec department.

BYOD Policy

Personal devices are subject to security evaluations prior to admittance to the organization's network. Device compliance is subject to change without notice and must meet criteria deemed acceptable by the InfoSec team.

Compliance requirements include but are not limited to utilizing the Microsoft 10 operating system with the latest security patches, iOS 17.4.0 or higher, Android 14.0 or higher, utilization of location services, the inclusion of password protection, reporting lost or stolen devices, antivirus installed on laptop devices, firewalls enabled on laptop devices, and the use of a VPN when accessing company resources outside the organization's network.

Noncompliant devices are required to go through software and hardware evaluations by the InfoSec team and may be subject to necessary adjustments to ensure compliance. Devices are also subject to randomized internal or external audits.

BYOD Policy Compliance

The InfoSec team is tasked with the verification of policy compliance through various methods, including but not limited to mobile devices management (MDM) solutions, video monitoring, intrusion detection tools, internal or external audits, network monitoring, and feedback from internal or external sources.

Employees found in violation of security policy will be subject to disciplinary actions according to the severity and number of violations.
Each violation will be detailed and stored in the employee's permanent file.
The device utilized in a violation is subject to software and hardware inspection by the InfoSec team.

Disciplinary actions may include, but are not limited to a formal written warning, a verbal warning, mandated training, a limitation of company privileges, legal consequences, internal or external audits, and possible termination of employment.

BYOD Related Standards, Policies, and Processes

All company policies will uphold the laws and regulations mandated by federal and local governance.

HIPPA and PCI-DSS standards are to be followed to maintain confidentiality for the health and financial information accessed through personal devices.
Availability is of the utmost importance, however, not at the cost of the integrity of data within the network.
HIPAA states the use of mobile devices to access electronic protected health information (ePHI) is permitted if appropriate physical, administrative, and technical safeguards are in place to protect the confidentiality, integrity, and availability of the ePHI on the mobile device.
The privacy and security concerns associated with the electronic transmission of health information are set forth by the HITECH Act Enforcement Interim Final Rule and must be obeyed.

PCI-DSS standards states a secure environment must be maintained to protect the processing, storage and transmission of credit card information. The protection of client data is of the upmost importance.
Any violation conveys a breach of trust, sheds a negative light on the organization and violates an individual or organization’s rights mandated by law.

BYOD Definitions and Terms

BYOD: Bring Your Own Device (BYOD) refers to a policy that determines when and how employees, contractors, and other authorized end users can use their own laptops, smartphones and other personal devices on the company network to access corporate data and perform their job duties.

CIA: refers to confidentiality, integrity and availability when describing a model designed to guide policies for information security (infosec) within an organization.

Firewall: computer hardware or software that prevents unauthorized access to private data (as on a company's local area network or intranet) by outside computer users.

HIPAA: The Health Insurance Portability and Accountability Act of 1996 (HIPAA) is a federal law that required the creation of national standards to protect sensitive patient health information from being disclosed without the patient’s consent or knowledge.

InfoSec: Information security, often referred to as InfoSec, refers to the processes and tools designed and deployed to protect sensitive business information from modification, disruption, destruction, and inspection.

BYOD Definitions and Terms

Intrusion Detection System: Also referred to IDS, detect attacks by capturing and analyzing network packets. One network-based IDS can monitor the network traffic affecting multiple hosts that are connected to the network.

Noncompliance Device: A device that doesn't meet the compliance policy standards and is therefore marked as noncompliant.

PCI-DSS Standards: An information security standard administered by the Payment Card Industry Security Standards Council that is for organizations that handle branded credit cards from the major card schemes.

Remediation: The neutralization or elimination of a vulnerability or the likelihood of its exploitation.

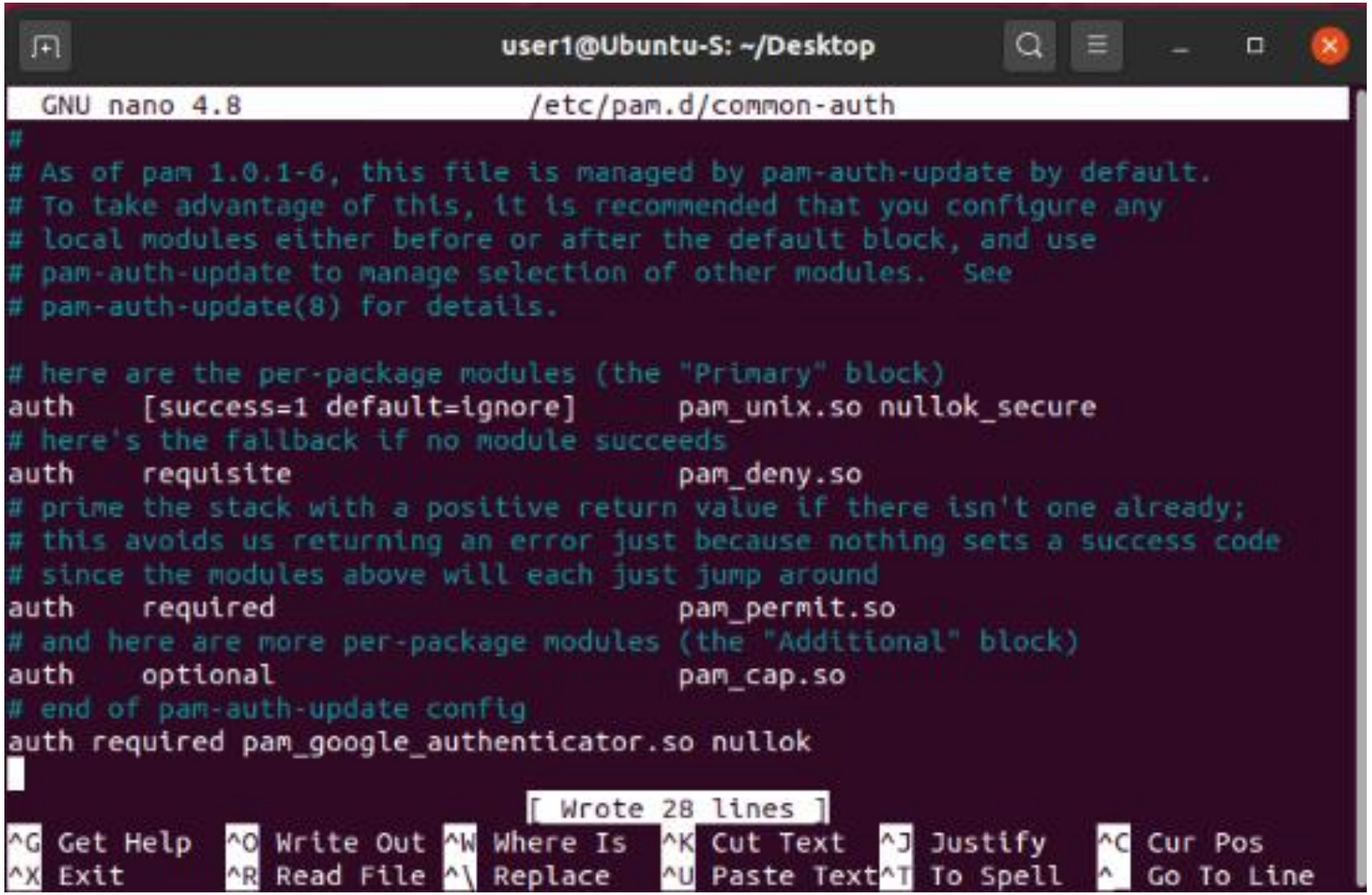
Security Policy: A set of rules that governs all aspects of security-relevant system behavior.

BYOD Revision History

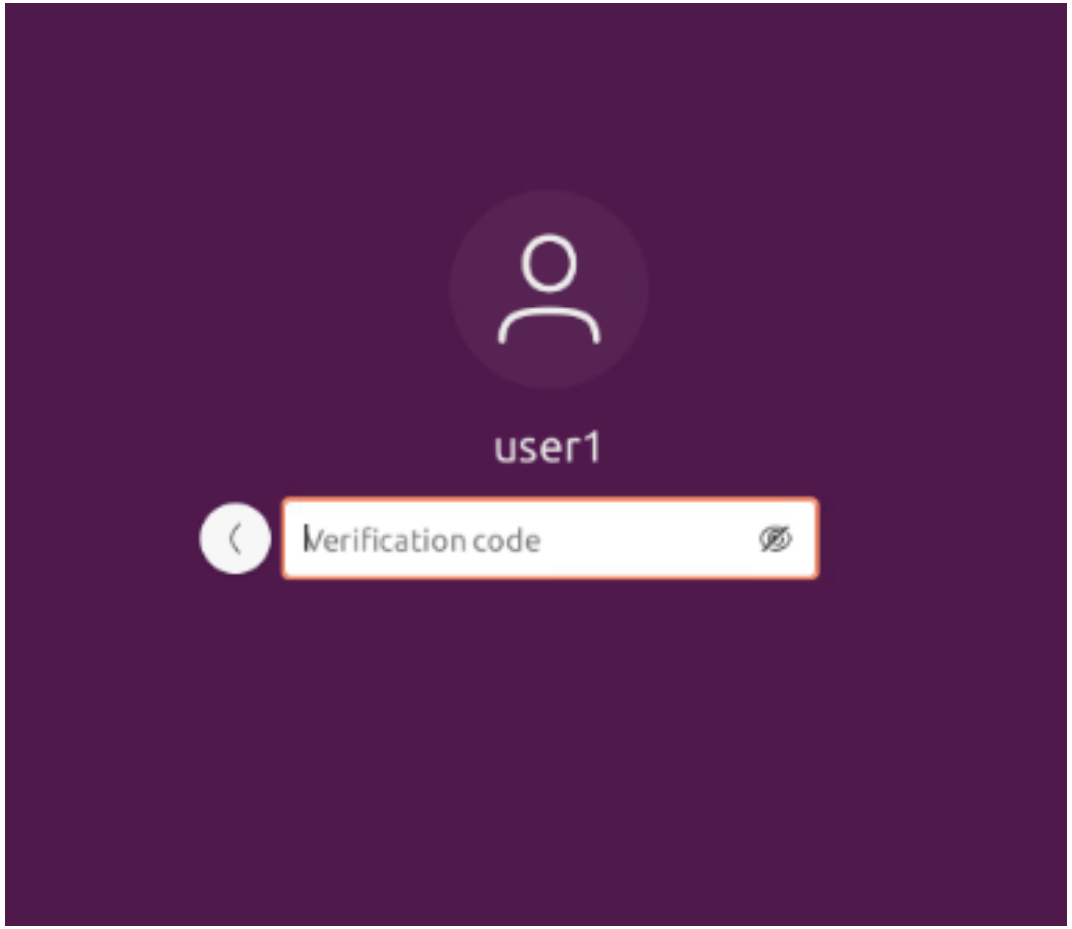
Date of change	Responsible	Summary of change
August 2019	SANS policy team	Updated and converted to new format
March 2024	Francisco Acosta	Creation of Bring Your Own Device (BYOD) Policy

Multifactor Authentication (MFA)

Common-auth Configuration File

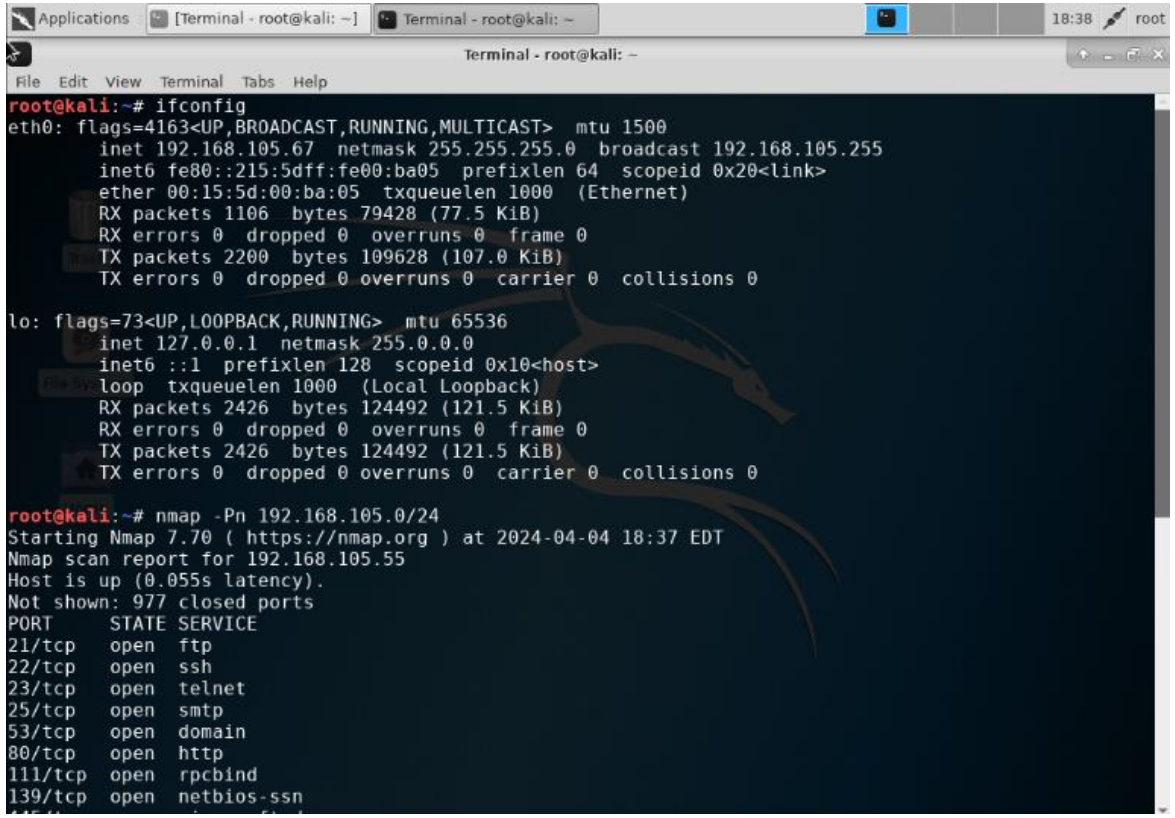


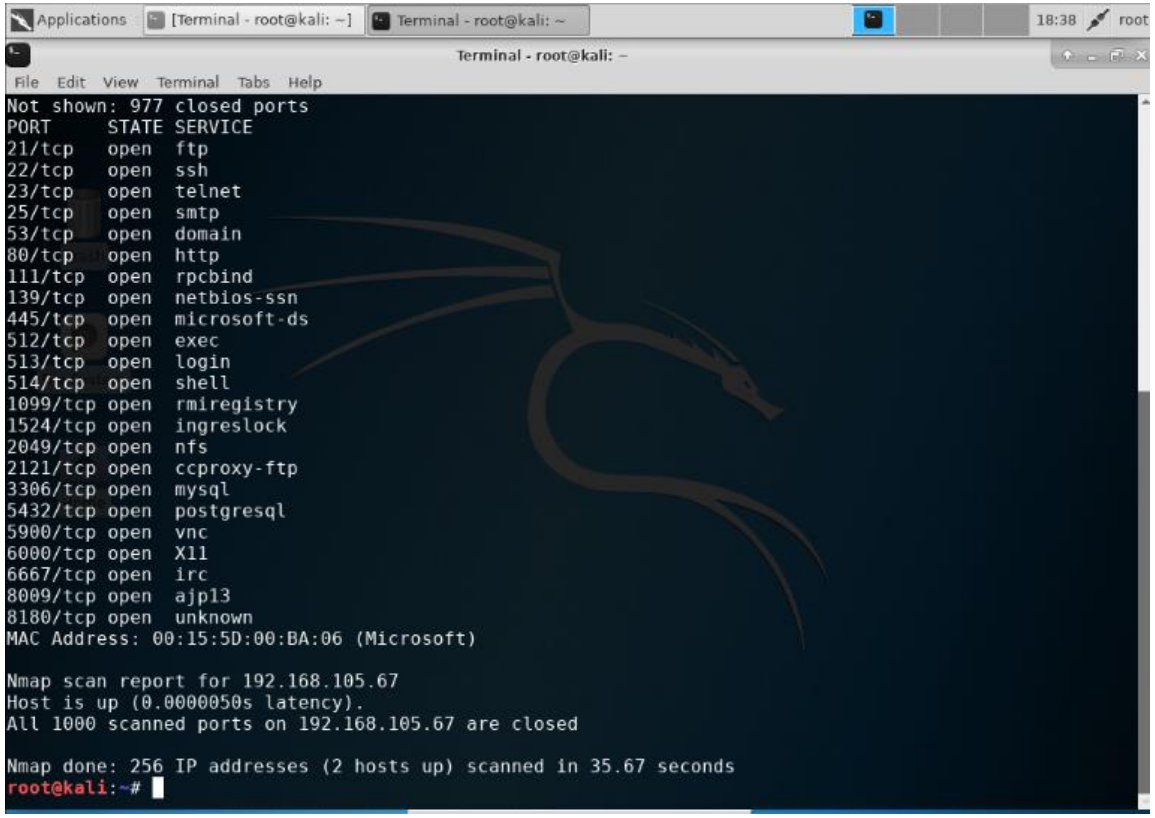
MFA Logon Screen



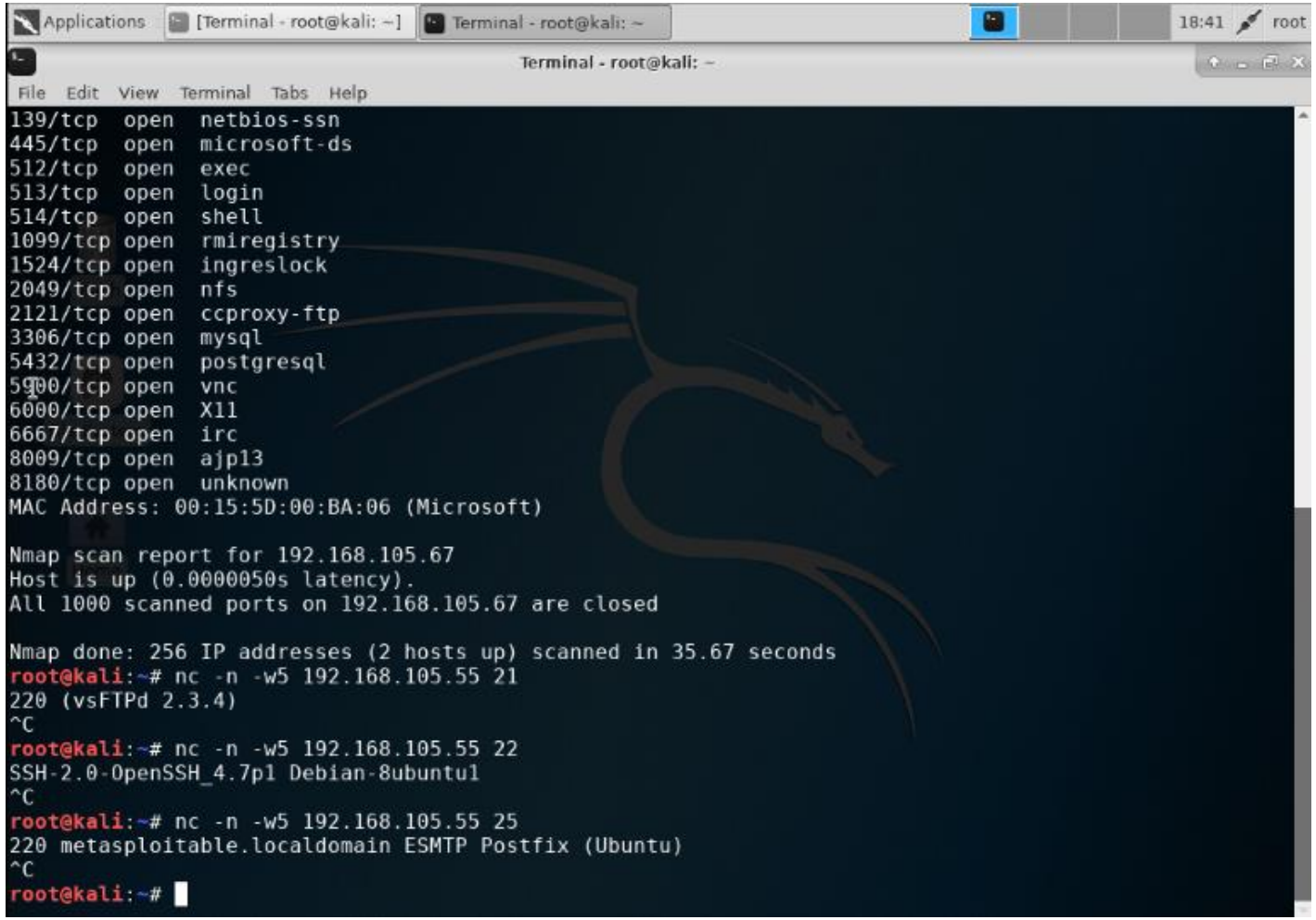
Vulnerability Assessment

Nmap

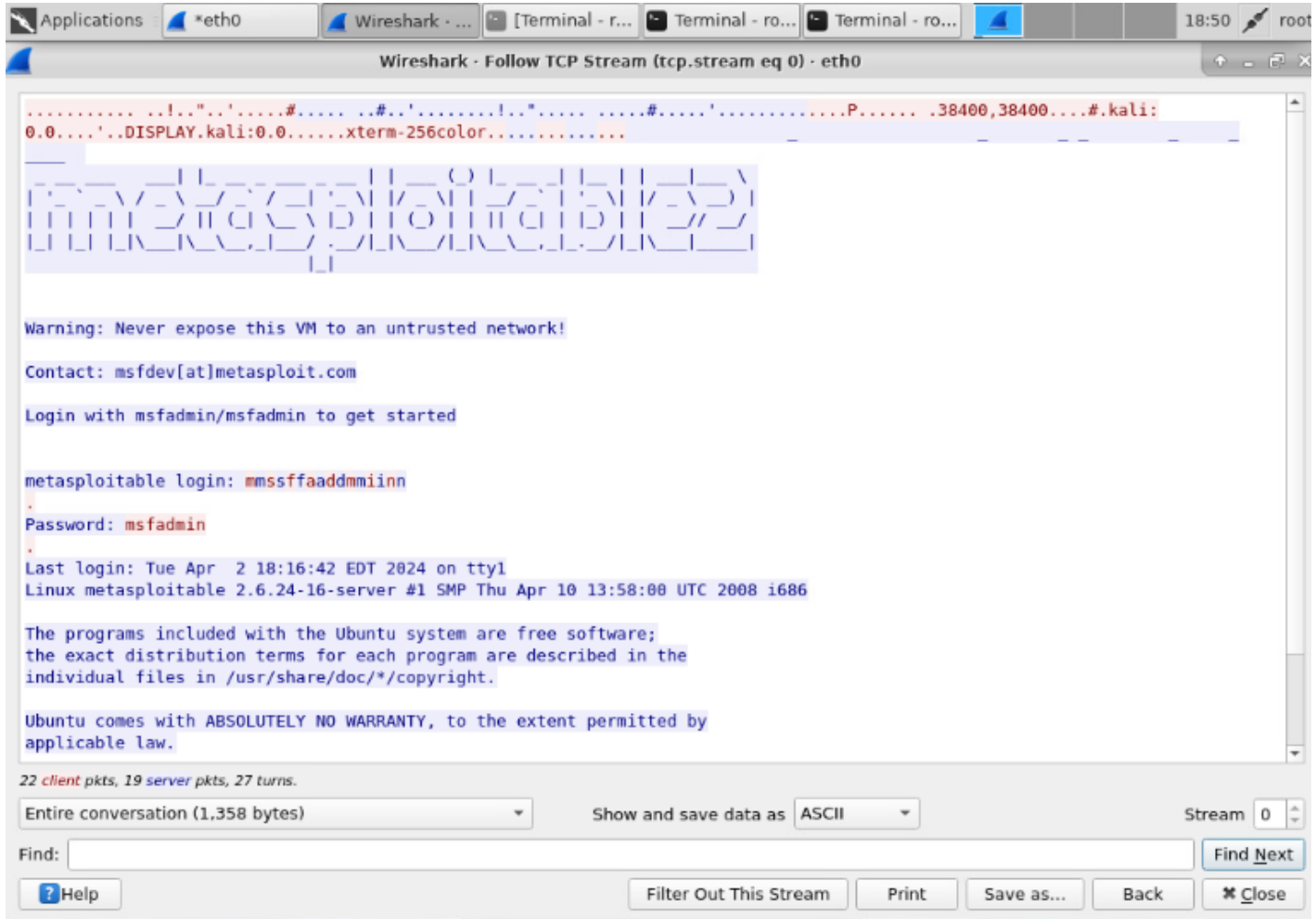

Applications
[Terminal - root@kali: ~]
Terminal - root@kali: ~
18:38
root
Terminal - root@kali: ~
File Edit View Terminal Tabs Help
root@kali:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
inet 192.168.105.67 netmask 255.255.255.0 broadcast 192.168.105.255
inet6 fe80::215:5dff:fe00:ba05 prefixlen 64 scopeid 0x20<link>
ether 00:15:5d:00:ba:05 txqueuelen 1000 (Ethernet)
RX packets 1106 bytes 79428 (77.5 KiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 2200 bytes 109628 (107.0 KiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
inet 127.0.0.1 netmask 255.0.0.0
inet6 ::1 prefixlen 128 scopeid 0x10<host>
loop txqueuelen 1000 (Local Loopback)
RX packets 2426 bytes 124492 (121.5 KiB)
RX errors 0 dropped 0 overruns 0 frame 0
TX packets 2426 bytes 124492 (121.5 KiB)
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
root@kali:~# nmap -Pn 192.168.105.0/24
Starting Nmap 7.70 (https://nmap.org) at 2024-04-04 18:37 EDT
Nmap scan report for 192.168.105.55
Host is up (0.055s latency).
Not shown: 977 closed ports
PORT STATE SERVICE
21/tcp open ftp
22/tcp open ssh
23/tcp open telnet
25/tcp open smtp
53/tcp open domain
80/tcp open http
111/tcp open rpcbind
139/tcp open netbios-ssn


Applications
[Terminal - root@kali: ~]
Terminal - root@kali: ~
18:38
root
Terminal - root@kali: ~
File Edit View Terminal Tabs Help
Not shown: 977 closed ports
PORT STATE SERVICE
21/tcp open ftp
22/tcp open ssh
23/tcp open telnet
25/tcp open smtp
53/tcp open domain
80/tcp open http
111/tcp open rpcbind
139/tcp open netbios-ssn
445/tcp open microsoft-ds
512/tcp open exec
513/tcp open login
514/tcp open shell
1099/tcp open rmiregistry
1524/tcp open ingreslock
2049/tcp open nfs
2121/tcp open ccproxy-ftp
3306/tcp open mysql
5432/tcp open postgresql
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
8009/tcp open ajp13
8180/tcp open unknown
MAC Address: 00:15:5D:00:BA:06 (Microsoft)
Nmap scan report for 192.168.105.67
Host is up (0.0000050s latency).
All 1000 scanned ports on 192.168.105.67 are closed
Nmap done: 256 IP addresses (2 hosts up) scanned in 35.67 seconds
root@kali:~#

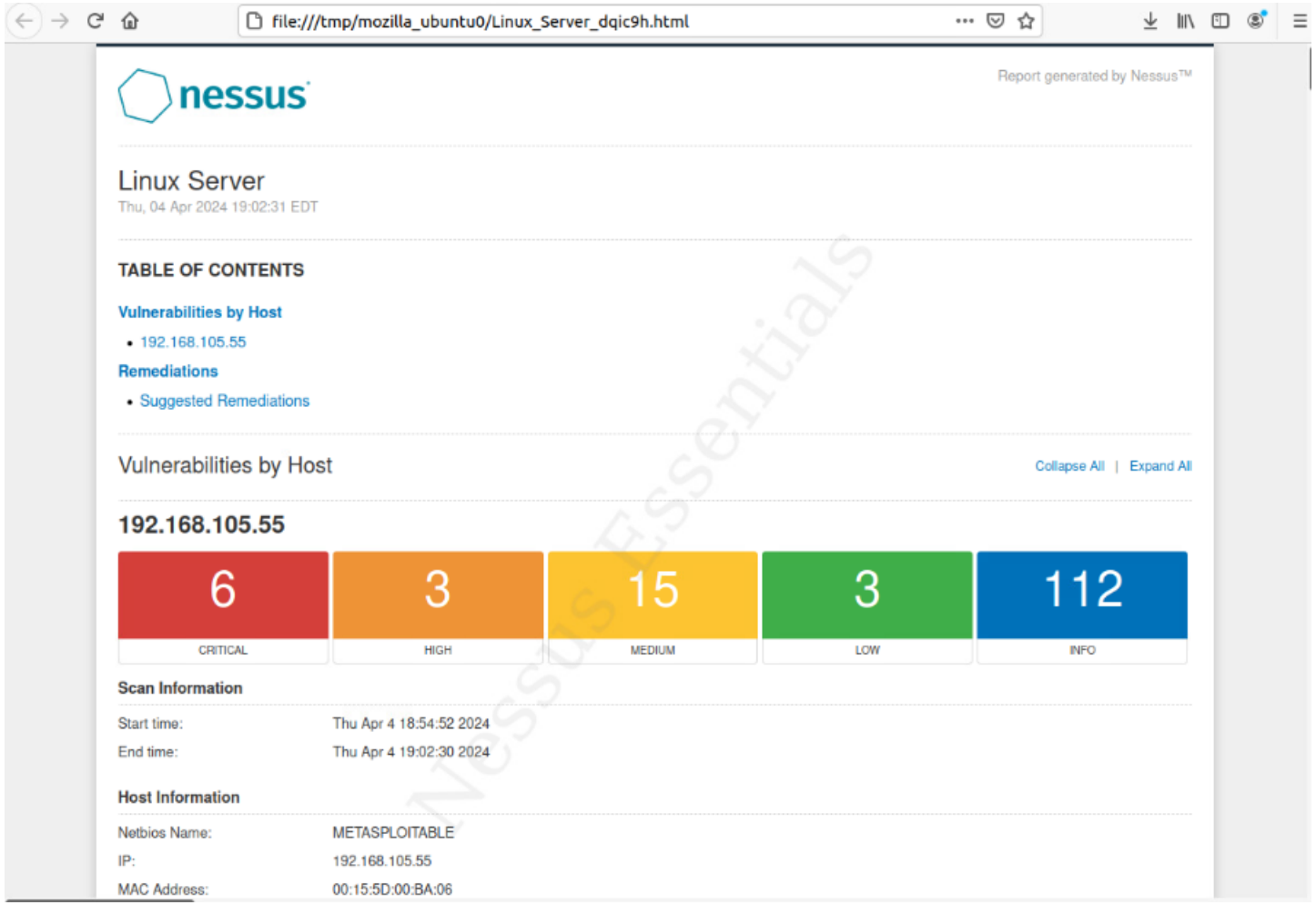
NetCat


Applications
[Terminal - root@kali: ~]
Terminal - root@kali: ~
18:41
root
Terminal - root@kali: ~
File Edit View Terminal Tabs Help
139/tcp open netbios-ssn
445/tcp open microsoft-ds
512/tcp open exec
513/tcp open login
514/tcp open shell
1099/tcp open rmiregistry
1524/tcp open ingreslock
2049/tcp open nfs
2121/tcp open ccproxy-ftp
3306/tcp open mysql
5432/tcp open postgresql
5900/tcp open vnc
6000/tcp open X11
6667/tcp open irc
8009/tcp open ajp13
8180/tcp open unknown
MAC Address: 00:15:5D:00:BA:06 (Microsoft)
Nmap scan report for 192.168.105.67
Host is up (0.0000050s latency).
All 1000 scanned ports on 192.168.105.67 are closed
Nmap done: 256 IP addresses (2 hosts up) scanned in 35.67 seconds
root@kali:~# nc -n -w5 192.168.105.55 21
220 (vsFTPd 2.3.4)
^C
root@kali:~# nc -n -w5 192.168.105.55 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
^C
root@kali:~# nc -n -w5 192.168.105.55 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
^C
root@kali:~#

Wireshark


Applications
*eth0
Wireshark · ...
[Terminal - r...
Terminal - ro...
Terminal - ro...
18:50
root
Wireshark · Follow TCP Stream (tcp.stream eq 0) · eth0
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login: mmssffaaddmmiinn
Password: msfadmin
Last login: Tue Apr 2 18:16:42 EDT 2024 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
22 client pkts, 19 server pkts, 27 turns.
Entire conversation (1,358 bytes)
Show and save data as
ASCII
Stream
0
Find:
Find Next
Help
Filter Out This Stream
Print
Save as...
Back
Close

Nessus


file:///tmp/mozilla_ubuntu0/Linux_Server_dqic9h.html
nessus
Report generated by Nessus™
Linux Server
Thu, 04 Apr 2024 19:02:31 EDT
TABLE OF CONTENTS
Vulnerabilities by Host
192.168.105.55
Remediations
Suggested Remediations
Vulnerabilities by Host
Collapse All | Expand All
192.168.105.55
6
CRITICAL
3
HIGH
15
MEDIUM
3
LOW
112
INFO
Scan Information
Start time: Thu Apr 4 18:54:52 2024
End time: Thu Apr 4 19:02:30 2024
Host Information
Netbios Name: METASPLOITABLE
IP: 192.168.105.55
MAC Address: 00:15:5D:00:BA:06
Nessus Essentials

Challenges

Challenges

Challenges are part of any project, and this module was no exception.
Below are a list of obstacles encountered throughout this module.

- The first challenge was establishing working knowledge of file encryption and decryption processes through the Command Line Interface (CLI).
- The second challenge was researching and developing a Bring Your Own Device (BYOD) policy. These policies have many moving parts and need to account for all aspects of an organization and may quickly become cumbersome if the correct knowledge is not attained.
- The last challenge was gaining working knowledge of various vulnerability assessment tools such as Nmap, NetCat, Wireshark, and Nessus. These all have varying work-flows and require in-depth knowledge of each user interface, as well as the utilization of the correct tools within each technology to complete the task at hand.

Challenges may arise from any situation, but the key triumph for me was the ability to overcome and learn from adversities faced.

Career Skills

Career Skills

A variety of career skills were learned throughout the process of comprehending information security and its application in real-world scenarios.

Acquired skills:

- Analysis of security threats
- Creation of solutions for preventing, isolating and mitigating risks
- Working knowledge of the Microsoft Hyper-V environment
- Network testing, configurations and troubleshooting
- Practical application of key encryptions and firewalls
- Creation of a Bring Your Own Devices (BYOD) policy
- Multi-Factor Authentication (MFA)
- Assessing vulnerabilities

Conclusions

Conclusions

This module demonstrates my competencies regarding the core principles of information security which consists of the confidentiality, integrity and availability of data.

I was able to demonstrate practical application of information security measures in real-world scenarios by analyzing security threats, implementing solutions, as well as the preventing, isolating, and mitigating risks.

Sufficient expertise has been displayed in multiple technologies consisting of the Microsoft Hyper-V environment, the Command Line Interface (CLI), Nmap, Multi-factor authentication (MFA), the Linux Ubuntu operating system, the Kali Linux operating system, NetCat, Wireshark, and Nessus.

I appreciate your time and I am thankful for the opportunity to learn, as well as apply learned skills throughout this module.

References

References

Ani Petrosyan. Statista. 31 Mar, 2023.
https://www.statista.com/statistics/1147490/share-adults-use-personal-smartphone-business-activities-by-country/

Cameron Hashemi-Pour. TechTarget. Dec 2023.
https://www.techtarget.com/whatis/definition/Confidentiality-integrity-and-availability-CIA

Centers for Disease Control and Prevention. Health Insurance Portability and Accountability Act of 1996 (HIPAA).
https://www.cdc.gov/phlp/publications/topic/hipaa.html

Cisco.
https://www.cisco.com/c/en/us/products/security/what-is-information-security-infosec.html

DeVry. Module 3 - Project: Stateful Firewall Submission Documentation.
https://devryu.instructure.com/courses/106657/assignments/3314089?module_item_id=13674606

References

Forbes. The Untethered Executive: Business Information in the Age of Mobility.
https://images.forbes.com/forbesinsights/StudyPDFs/The_Untethered_Executive.pdf

IBM.
https://www.ibm.com/docs/en/linux-on-systems?topic=tests-firewall-iptables-rules

IBM. What is bring your own device (BYOD)?.
https://www.ibm.com/topics/byod

IBM. Mobile device management (MDM) solutions
https://www.ibm.com/products/maas360/mobile-device-management?utm_content=SRCWW&p1=Search&p4=43700066577516546&p5=e&gad_source=1&gclid=Cj0KCQjw-_mvBhDwARIsAA-Q0Q5RBTn74tgmnQqW16aBmemybnmB-uJhLP3xpZBSQb4PTYJnE74b69IaArbyEALw_wcB&gclsrc=aw.ds

References

National Institute of Standards and Technology.
https://csrc.nist.gov/glossary

Norton. 08, Aug 2018.
https://us.norton.com/blog/mobile/types-of-common-mobile-threats-and-what-they-can-do-to-your-phone

Merriam-Webster.
https://www.merriam-webster.com/

US Department of Health and Human Services.
https://www.hhs.gov/hipaa/for-professionals/faq/2081/do-the-hipaa-rules-allow-health-care-providers-to-use-mobile-devices-to-access-ephi-in-a-cloud/index.html

US Department of Health and Human Services.
https://www.hhs.gov/hipaa/for-professionals/special-topics/hitech-act-enforcement-interim-final-rule/index.html